

Autores:	Dr. Gorka Altube Urizar (BCAM — Basque Center for Applied Mathematics) · Dra. Leire Mendizabal Olabarria (UPV/EHU, Dpto. Informática) · Ander Zubizarreta Arrieta (CIO, Grupo Mondragon)
Revisores:	Comité Técnico DIGIBASK · Agencia Vasca de Ciberseguridad (ZIUR) · SPRI — Agencia Vasca de Desarrollo Empresarial
Clasificación:	DIFUSIÓN RESTRINGIDA — Para uso interno de entidades adheridas a DIGIBASK. No reproducir sin autorización.

RESUMEN EJECUTIVO

El presente informe analiza el estado de adopción de los Modelos de Lenguaje Grande (Large Language Models, LLM) en entornos corporativos vascos, identificando los principales vectores de riesgo técnico, legal y operacional, y proponiendo un marco de gobernanza adaptado a las exigencias del Reglamento Europeo de Inteligencia Artificial (AI Act, Reglamento UE 2024/1689) y la normativa de protección de datos (RGPD). El análisis se basa en encuestas a 47 organizaciones del tejido empresarial vasco (industria, servicios, Administración Pública), entrevistas con 23 responsables técnicos y el estudio de 12 casos de implementación real durante 2023-2024. Los resultados muestran que el 67% de las organizaciones analizadas han iniciado proyectos piloto con LLMs, pero solo el 19% dispone de una política de gobernanza de IA formalmente aprobada. Las principales barreras identificadas son: riesgo de fuga de datos confidenciales a proveedores cloud (78% de los encuestados lo citan como preocupación principal), dificultad para auditar y explicar las decisiones de los modelos (61%), y falta de personal técnico especializado (54%).

1. INTRODUCCIÓN Y CONTEXTO

La irrupción de ChatGPT (noviembre 2022) y la posterior proliferación de LLMs comerciales (GPT-4, Claude, Gemini, Llama) y de código abierto ha precipitado una aceleración sin precedentes en la adopción de IA generativa en el tejido empresarial. Según datos de McKinsey Global Institute (2024), el 72% de las empresas globales con más de 1.000 empleados reportan uso activo de herramientas de IA generativa en al menos una función de negocio, frente al 33% en 2022. En el contexto vasco, el Clúster de Conocimiento de Euskadi estima que el impacto potencial de la IA generativa sobre la productividad del sector servicios podría suponer un incremento del 12-18% en los próximos cinco años, si bien advierte de que dicho potencial está condicionado a una gestión adecuada de los riesgos asociados.

2. TAXONOMÍA DE RIESGOS EN IMPLANTACIONES LLM

Los riesgos identificados se clasifican en cuatro categorías principales:

2.1 RIESGOS DE SEGURIDAD Y PRIVACIDAD DE DATOS La principal amenaza en entornos corporativos es la transmisión involuntaria de información confidencial a sistemas de terceros (proveedores de LLM cloud). En los modelos comerciales de GPT-4 y Claude en sus versiones de consumo, los datos de las conversaciones pueden ser utilizados para el entrenamiento de modelos futuros salvo que se haya contratado un acuerdo empresarial específico (Azure OpenAI Service, API con DPA firmado). Se han documentado 14 incidentes de filtración de datos en empresas europeas durante 2024 relacionados con el uso inadecuado de LLMs.

2.2 RIESGOS DE ALUCINACIÓN Y CALIDAD DE OUTPUTS Los LLMs presentan una tasa de generación de

contenido factualmente incorrecto ('alucinaciones') que varía entre el 3% y el 27% según el tipo de tarea y el modelo empleado (Stanford HELM Benchmark, 2024). En aplicaciones críticas como asistencia jurídica, diagnóstico médico o elaboración de informes financieros, estas tasas son inaceptables sin mecanismos de validación humana. El caso paradigmático fue el de un bufete de abogados de Nueva York que presentó un escrito con seis citas jurisprudenciales completamente inventadas por ChatGPT (caso Mata v. Avianca, 2023).

2.3 RIESGOS REGULATORIOS Y DE CUMPLIMIENTO NORMATIVO El AI Act europeo clasifica los sistemas de IA según su nivel de riesgo (inaceptable, alto, limitado, mínimo). Los LLMs de propósito general (GPAI) quedan sometidos a obligaciones específicas de transparencia, documentación técnica y evaluación de cumplimiento. Las organizaciones que desplieguen LLMs para usos de alto riesgo (ej. sistemas de RRHH, evaluación crediticia, seguridad de infraestructuras) deberán inscribirse en el registro de la base de datos de la UE y superar auditorías de conformidad.

2.4 RIESGOS OPERACIONALES Y DE DEPENDENCIA TECNOLÓGICA El 43% de las organizaciones encuestadas reporta dependencia crítica de un único proveedor LLM, sin estrategia de contingencia documentada. Los cambios en las condiciones de servicio, precios o discontinuación de modelos por parte de OpenAI, Anthropic o Google pueden tener impacto operacional severo en los flujos de trabajo que han sido rediseñados en torno a estas herramientas.

3. MARCO DE GOBERNANZA PROPUESTO

Se propone un marco de gobernanza de cinco capas, alineado con el AI Act y las guías del European AI Office:

CAPA 1 — CLASIFICACIÓN Y REGISTRO DE CASOS DE USO: Las organizaciones deben mantener un inventario actualizado de todos los casos de uso de IA, clasificados según el nivel de riesgo del AI Act. Se recomienda el uso de la herramienta AI Use Case Registry de la Comisión Europea (versión 2.0, disponible desde enero 2025) o equivalente corporativo.

CAPA 2 — EVALUACIÓN DE IMPACTO (AI IMPACT ASSESSMENT): Obligatoria para sistemas de alto riesgo y recomendada para todos los demás. Debe incluir: análisis de datos de entrenamiento, evaluación de sesgos algorítmicos, análisis de privacidad (DPIA conforme al RGPD), plan de gestión de incidentes y protocolo de supervisión humana.

CAPA 3 — POLÍTICA DE USO ACEPTABLE (AUP): Definir qué información puede y no puede compartirse con LLMs externos, qué tipos de decisiones requieren validación humana y cuáles son los procedimientos ante alucinaciones o errores detectados.

CAPA 4 — FORMACIÓN Y ALFABETIZACIÓN EN IA: El AI Act exige que el personal que utilice sistemas de IA cuente con un nivel adecuado de 'alfabetización en IA'. Se recomiendan programas de formación diferenciados por perfil (usuarios básicos, desarrolladores, directivos) con actualización anual mínima.

CAPA 5 — AUDITORÍA Y MONITORIZACIÓN CONTINUA: Implementar mecanismos de logging de interacciones con LLMs, métricas de calidad de outputs (hallucination rate, faithfulness, relevance), revisiones periódicas de los casos de uso activos y procedimiento de retirada de servicio cuando el riesgo supere umbrales definidos.

4. CONCLUSIONES Y RECOMENDACIONES

La adopción de LLMs en entornos corporativos presenta un potencial de transformación significativo, pero requiere un enfoque estructurado que equilibre la innovación con la gestión de riesgos. Las principales recomendaciones del

grupo de trabajo son:

1. Priorizar despliegues con LLMs en modalidad privada (self-hosted o Azure/AWS con DPA) para casos de uso que impliquen datos confidenciales o personales.
2. Implementar siempre supervisión humana para outputs que afecten a decisiones con consecuencias relevantes para personas (RRHH, clientes, operaciones críticas).
3. Adoptar el marco OWASP Top 10 for LLM Applications (versión 2025) como referencia de seguridad en el desarrollo e implantación de aplicaciones basadas en LLMs.
4. Iniciar el proceso de clasificación de casos de uso conforme al AI Act con antelación suficiente a la entrada en vigor de las obligaciones para sistemas de alto riesgo (agosto 2026).
5. Invertir en capacidades internas de evaluación de modelos: las organizaciones que dependen exclusivamente de los benchmarks publicados por los propios proveedores asumen un riesgo de evaluación sesgada.

Limitaciones del estudio: El tamaño muestral (47 organizaciones) limita la generalización de los resultados al conjunto del tejido empresarial vasco. La rapidez de evolución del sector hace que algunos datos cuantitativos puedan haber variado desde el cierre del trabajo de campo (diciembre 2024). Se recomienda actualización anual del presente informe.

REFERENCIAS BIBLIOGRÁFICAS Y NORMATIVAS

[1] Reglamento (UE) 2024/1689 del Parlamento Europeo y del Consejo, de 13 de junio de 2024, por el que se establecen normas armonizadas en materia de inteligencia artificial (Reglamento de Inteligencia Artificial). DOUE L, 12.7.2024.

[2] OWASP Foundation (2025). OWASP Top 10 for Large Language Model Applications, v2025.0. <https://owasp.org/www-project-top-10-for-large-language-model-applications/>

[3] McKinsey Global Institute (2024). The State of AI in 2024: GenAI adoption accelerates. McKinsey & Company.

[4] Liang, P. et al. (2024). Holistic Evaluation of Language Models (HELM). Stanford CRFM. <https://crfm.stanford.edu/helm/>

[5] European AI Office (2025). Guidelines for providers of general-purpose AI models. Comisión Europea.

[6] Mata v. Avianca, Inc., 22-cv-1461 (S.D.N.Y. 2023). Orden del juez Castel de 22 de junio de 2023.

[7] Agencia Española de Protección de Datos (2024). Guía sobre inteligencia artificial y protección de datos. AEPD.